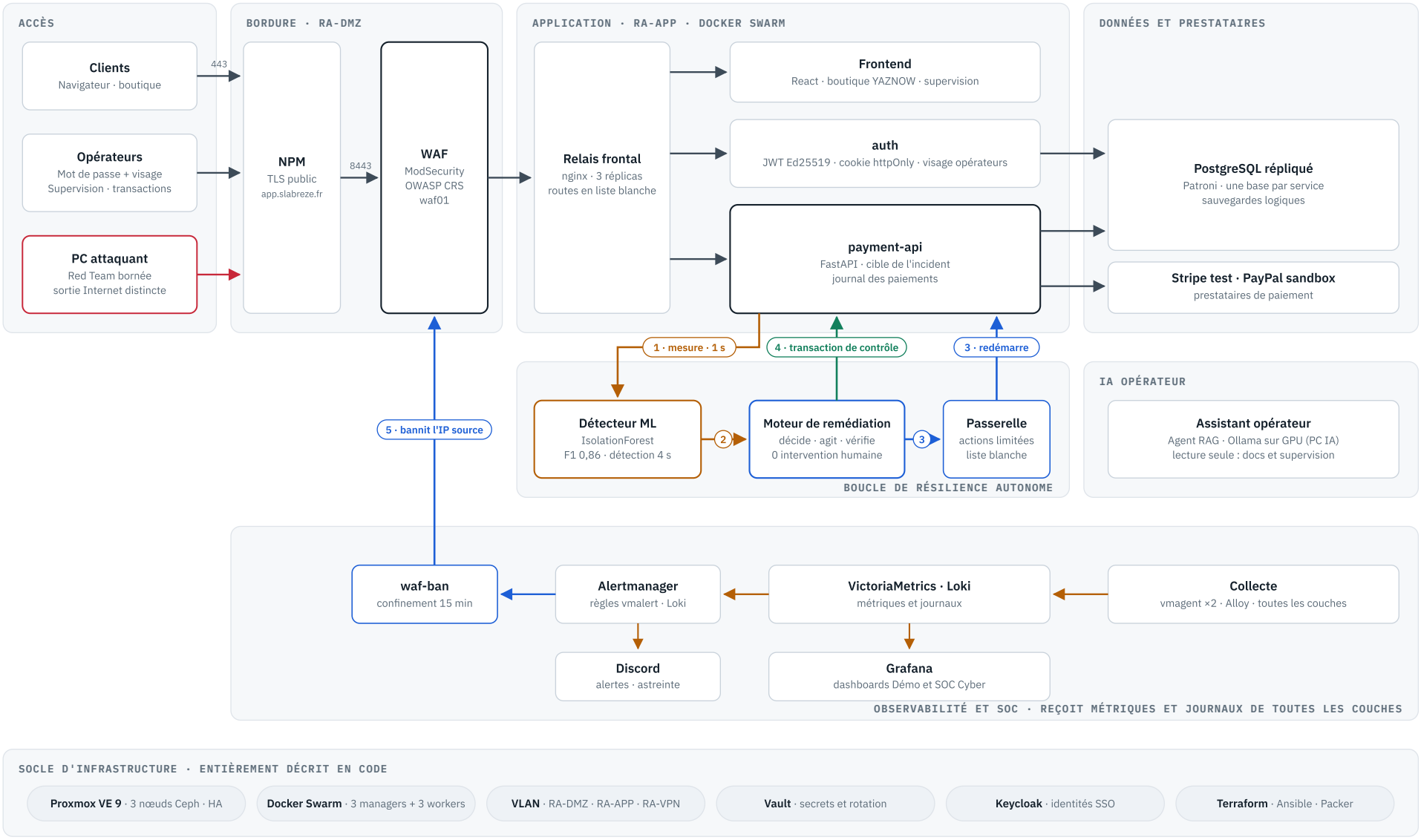
M2 EPSI · WORKSHOP 2026 · ARCHITECTURE DE RÉFÉRENCE

Project RESILIENCE-ALPHA

Plateforme de paiement qui filtre l'entrée, détecte l'anomalie par apprentissage, se répare seule et prouve la reprise par une transaction réelle.




ACCÈS
Clients
Navigateur · boutique
Opérateurs
Mot de passe + visage
Supervision · transactions
PC attaquant
Red Team bornée
sortie Internet distincte
443
BORDURE · RA-DMZ
NPM
TLS public
app.slabreze.fr
8443
WAF
ModSecurity
OWASP CRS
waf01
APPLICATION · RA-APP · DOCKER SWARM
Relais frontal
nginx · 3 réplicas
routes en liste blanche
Frontend
React · boutique YAZNOW · supervision
auth
JWT Ed25519 · cookie httpOnly · visage opérateurs
payment-api
FastAPI · cible de l'incident
journal des paiements
DONNÉES ET PRESTATAIRES
PostgreSQL répliqué
Patroni · une base par service
sauvegardes logiques
Stripe test · PayPal sandbox
prestataires de paiement
1 · mesure · 1 s
4 · transaction de contrôle
3 · redémarre
Détecteur ML
IsolationForest
F1 0,86 · détection 4 s
2
Moteur de remédiation
décide · agit · vérifie
0 intervention humaine
3
Passerelle
actions limitées
liste blanche
BOUCLE DE RÉSILIENCE AUTONOME
IA OPÉRATEUR
Assistant opérateur
Agent RAG · Ollama sur GPU (PC IA)
lecture seule : docs et supervision
5 · bannit l'IP source
waf-ban
confinement 15 min
Alertmanager
règles vmalert · Loki
VictoriaMetrics · Loki
métriques et journaux
Collecte
vmagent ×2 · Alloy · toutes les couches
Discord
alertes · astreinte
Grafana
dashboards Démo et SOC Cyber
OBSERVABILITÉ ET SOC · REÇOIT MÉTRIQUES ET JOURNAUX DE TOUTES LES COUCHES
SOCLE D'INFRASTRUCTURE · ENTIÈREMENT DÉCRIT EN CODE
Proxmox VE 9 · 3 nœuds Ceph · HA
Docker Swarm · 3 managers + 3 workers
VLAN · RA-DMZ · RA-APP · RA-VPN
Vault · secrets et rotation
Keycloak · identités SSO
Terraform · Ansible · Packer

Le chemin d'une requête se lit de gauche à droite. L'entrée publique passe par NPM puis le WAF en DMZ, seul point d'accès à l'application. La boucle autonome, sous l'application, mesure, décide, répare et prouve la reprise. La supervision et le socle sont transverses : chaque couche leur envoie métriques et journaux, sans flèche individuelle.

Le scénario de résilience, dans l'ordre

1. **Mesure.** Le détecteur lit l'état de l'API chaque seconde et calcule un score d'anomalie appris sur le trafic normal.
2. **Verdict.** Le score franchit le seuil plusieurs secondes de suite : anomalie confirmée.
3. **Action.** Le moteur recrée l'API à partir de son image saine, par une passerelle qui n'autorise que cette action.
4. **Preuve.** Une transaction de contrôle repasse : le service est déclaré rétabli, sans intervention humaine.
5. **Confinement, en parallèle.** Alertmanager fait bannir l'adresse source au WAF pendant 15 minutes.

Garanties de conception

- **Une seule entrée.** Tout passe par NPM puis le WAF ; les sondes et la supervision sont réservées aux opérateurs.
- **Des droits minimaux.** Le moteur ne touche jamais l'orchestrateur en direct : la passerelle n'accepte qu'une liste d'actions.
- **Une IA qui n'agit pas.** L'assistant lit la documentation et la supervision, il ne déclenche aucune action.
- **Aucun secret en clair.** Les secrets vivent dans Vault, l'infrastructure est entièrement décrite en code.